

CEHv13 A.I MODULE 12- Evading IDS, Firewalls & Honeypots

Notes by VIVEK GOSWAMI

Introduction to Firewall, IDS, and IPS

Firewall: A network security device that controls incoming and outgoing traffic based on predetermined rules. It acts as the first line of defence by blocking unauthorised access while allowing legitimate communication.

Intrusion Detection System (IDS): Monitors network and system activities for suspicious or malicious behaviour. An IDS alerts administrators when potential threats or policy violations are detected, but does not block traffic.

Intrusion Prevention System (IPS): Similar to IDS but operates inline to actively detect and block threats in real-time, preventing attacks such as malware infections, DDoS, and unauthorised access.

Deployment Types - HIDS & NIDS

1. **Host-based** - Monitors activity on a single device/host by being installed locally.
2. **Network-based** - Monitors activity across a network using remote sensors that report back to a central system. Often paired with a security Information & SIEM system for analysis. Often, Reverse ARP or Reverse DNS lookups are used to discover the source

Knowledge & Behavior-Based Detection:

1. **Knowledge Based (Signature-Based | Pattern Matching)** - Most common form of detection. Uses a database of profiles or signatures to assess all traffic against.
2. **Behavior Based (Statistical | Anomaly | Heuristic)** - Starts by creating a baseline of behavior for the monitored system/network and then compares all traffic against that looking for deviations. Can be labeled an AI or Expert system.

Firewalls - Basic Concepts

Firewalls are often seen as NAC devices. Use of rule sets to filter traffic can implement a security policy.*

1. Firewall types:

- **Stateful (Dynamic Packet Filtering)** - Layer 3 + 4 (Network + Transport layer)
- **Stateless (Static Packet Filtering) - Layer 3 (Network)**
- **Deep Packet Inspection** - Layer 7 (Application Layer)
- **Proxy Firewall** - Mediates communications between untrusted and trusted end-points (server/hosts/clients). A proxy firewall is a network security system that protects network resources by filtering messages at the Application Layer 7. A proxy firewall may also be called an application firewall or gateway firewall.

2. Proxy Types:

- **Circuit-level proxy** - Firewall that works on Layer 5 (Session layer); They monitor TCP handshaking between packets to determine whether a requested session is legitimate.
- **Application-level proxy** - Any service or server that acts as a proxy for client computer requests at the application layer.

An application-level proxy is one that knows about the particular application it is providing proxy services for; it understands and interprets the commands in the application protocol. A circuit-level proxy is one that creates a circuit between the client and the server without interpreting the application protocol.

Multi-homed Firewall (dual-homed) - Firewall that has two or more interfaces; One interface is connected to the untrusted network and another interface is connected to the trusted network. A DMZ can be added to a multi-homed firewall just by adding a third interface.

Bastion hosts - Endpoint that is exposed to the internet but has been hardened to withstand attacks; Hosts on the screened subnet designed to protect internal resources.

Screened host - Endpoint that is protected by a firewall.

Packet-filtering - Firewalls that only looked at headers

Only uses rules that implicitly deny traffic unless it is allowed.

Oftentimes uses network address translation(NAT) which can apply a one-to-one or one-to-many relationship between external and internal IP addresses.

Private zone - hosts internal hosts that only respond to requests from within that zone

Honeypots

Honeypots are decoy systems or servers deployed alongside production systems within your network. When deployed as enticing targets for attackers, honeypots can add security monitoring opportunities for blue teams and misdirect the adversary from their true target.*

Honeynet - Two or more honeypots on a network form a honeynet. Honeynets and honeypots are usually implemented as parts of larger Network Intrusion Detection Systems.

A Honeyfarm is a centralised collection of honeypots and analysis tools.

Types of Honeypots:

1. **Low-interaction** → Simulates/imitates services and systems that frequently attract criminal attention. They offer a method for collecting data from blind attacks such as botnets and worm malware.
2. **High interaction** → Simulates all services and applications and is designed to be completely compromised
3. **Production** → Serve as decoy systems inside fully operating networks and servers, often as part of an intrusion detection system (IDS). They deflect criminal attention from the real system while analysing malicious activity to help mitigate vulnerabilities.
4. **Research** → Used for educational purposes and security enhancement. They contain trackable data that you can trace when stolen to analyze the attack.

Honeypot Tools(2025)

1. **SecurityHive** – Plug-and-play honeypot with EU hosting and compliance.
2. **FortiDeceptor** – Enterprise deception platform integrated with Fortinet.
3. **Thinkst Canary** – Easy deployment, low maintenance, reliable alerts.
4. **T-Pot** – Open-source platform combining 20+ honeypots with Elastic Stack.
5. **Cowrie** – SSH and Telnet honeypot for deep attacker telemetry.
6. **Dionaea** – Low-interaction multi-protocol malware honeypot.
7. **OpenCanary** – Lightweight honeypot emulating common services.
8. **Express-honeypot** – Node.js based honeypot detecting web attacks.
9. **RIoTPot** – IoT honeypot supporting multiple IoT protocols.
10. **Beehive Redis (redis-honeypot)** – Emulates Redis to detect unauthorized access.
11. **Spectre**: Commercial low-interaction honeypot by NetSec.

Evading with Nmap

Useful switches for Evading and Stealthy:

FLAGS	INFORMATION
-v	Verbose level
-sS	TCP SYN scan
-T	Time template for performing the scan
-f	Use fragmented IP packets
-f -mtu	Use fragmented packets & set MTU (Maximum Transmission Unit. It is the largest size of data packet (in bytes) that can be transmitted in a single network layer transaction without needing to be fragmented.)
-D	IP address Decoy: <decoy1,decoy2[,ME],...>: Cloak a scan with decoys
-S	Spoof the source IP address
--send-eth	Ensures that we use Ethernet-level packets. bypassing the IP layer and sending raw Ethernet frames within the flow
--data-length	Specify the length of data/frame
--source-port	Specify a randomized port that you want to communicate

Example:

- Sends IPv4 fragmented 50-byte packet size; The packets are too small to send data and to detect as a Probe/Scanning technique:

→nmap -v -sS -f -mtu 32 --send-eth --data-length 50 --source-port 8965 -T5 192.168.0.22`

Fragmentation is the heart of the IDS/Firewall Evasion techniques.

Using SNORT

SNORT is an open source network intrusion detection system (NIDS). Snort is a packet sniffer that monitors network traffic in real time, scrutinising each packet closely to detect a dangerous payload or suspicious anomalies.

- Snort is a widely deployed IDS that is open source
- Includes a sniffer, traffic logger and a protocol analyser
- Runs in three different modes
 1. Sniffer - Watches packets in real time
 2. Packet logger - Saves packets to disk for review at a later time
 3. NIDS - Analyses network traffic against various rule sets
- Configuration is in ``etc/snort`` on Linux and ``C:\snort\etc`` in Windows; the file is `snort.conf`.

SNORT basics commands:

Operational modes:

- Snort as Sniffer ----> ``snort -v``

- Snort as Packet logger ----> ``snort -l``

- Snort as NIDS ----> ``snort -A`` or ``snort -c <path_to_conf_file>``

Example of usage:

1. `snort -i 4 -l c:\Snort\log -c c:\Snort\etc\snort.conf -T`

This command will test Snort configuration and rules and check if there is any errors without starting up.

- `-i 4` → interface specifier, in case is interface 4.
- `-l` → for logging
- `-c` → use Snort rules file specifying path
- `-T` → Only For testing, this prevent Snort from start up; Essentially to check if there is any errors and if the rules are good.

2. `snort -i 4 -c c:\Snort\etc\snort.conf -l c:\Snort\log -K ascii`

This command will fire up Snort NIDS and log everything in ASCII.

Basic commands:

Flag | Information

FLAG	INFORMATION
-A	Set alert mode: fast, full, console, test or none
-b	Log packets in tcpdump format (much faster!)
-B <mask>	Obfuscate IP addresses in alerts and packet dumps using CIDR mask
-c <rules>	Use Rules file
-C	Print out payloads with character data only (no hex)
-l	Specifies the logging directory (all alerts and packet logs are placed in this directory)
-i <interface number>	Specifies which interface Snort should listen on
-K	Logging mode (pcap[default], ascii, none)
-?	Lists all switches and options and then exits

SNORT Rules

SNORT has a rules engine that allows for customization of monitoring and detection capabilities.

There are three available rule actions

1. Alert
2. Pass
3. Log

And three available IP protocols:

1. TCP
2. UDP
3. ICMP

Firewall Evasion

Firewalking - Using TTL values to determine gateway ACL filters and allow for mapping of internal networks by analyzing IP packet responses; Going through every port on a firewall to determine what is open.

Banner Grabbing - Looking for FTP, TELNET and web server banners.

IP Address Spoofing - Hijacking technique allowing attacker to masquerade as a trusted host.

Source Routing - Allows the sender of a packet to partially or fully specify the route to be used.

Tiny Fragments - Successful with Firewalls when they ONLY CHECK for the TCP header info, allowing the fragmentation of the information across multiple packets to hide the true intention of the attack.

ICMP Tunneling - Allows for the tunnelling of a backdoor shell via the ICMP echo packets because the RFC (792) does not clearly define what kind of data goes in the data portion of the frame, allowing for attack traffic to be seen as acceptable when inserted. If firewalls do not examine the payload section of the dataframe, they would let the data through, allowing the attack.

ACK Tunnelling - Use of the ACK flag to trick the firewall into allowing packets, as many firewalls do not check ACK packets.

HTTP Tunnelling - Use of HTTP traffic to 'hide' attacks.

SSH Tunnelling - Use of SSH to encrypt and send attack traffic.

MitM Attacks - Use of DNS and routing manipulation to bypass firewalls.

XSS Attacks - Allows for the exploitation of vulnerabilities around the processing of input parameters from the end user and the server responses in a web application. The attacker injects malicious HTML/JS code into website to force the bypassing of the firewall once executed.

- Use IP in place of a URL - may work depending on nature of filtering in place
- Use Proxy Servers/Anonymizers - May work depending on nature of filtering in place
- ICMP Type 3 Code 13 will show that traffic is being blocked by firewall
- ICMP Type 3 Code 3 tells you the client itself has the port closed

Tools

CovertTCP

ICMP Shell

007 Shell

The best way around a firewall will always be a compromised internal machine

How to detect a Honeypot

Probe services running on them; Ports that show a service is available, but deny a three-way handshake may indicate that the system is a honeypot.

- Layer 7 (Application) - Examine latency of responses from server
- Layer 4 (Transport) - Examine the TCP windows size, looking for continuous Acknowledgement of incoming packets even when the windows size is set to 0.
- Layer 2 (Data Link) - If you are on the same network as the honeypot, look for MAC addresses in packets that indicate the presence of a 'Black Hole' ('0:0:f:ff:ff:ff')
- If Honeypot is virtualised, look for the vendor-assigned MAC address ranges as published by IEEE.
- If Honeypot is the Honeyd type, use time-based TCP fingerprinting methods to detect
- Detecting User-Mode Linux (UML) honeypot, analyse `proc/mounts`, `proc/interrupts` and `proc/cmdline`, which would have UML-specific settings and information.
- Detecting Sebek-based honeypots, Sebek will log everything that is accessed via `read()` before sending to the network, causing congestion that can be an indicator.
- Detecting snort_inline honeypots, analyse the outgoing packets by capturing the snort_inline modified packets through another

EXAMPLE COMMOND

View firewall rules (Linux - iptables)

→sudo iptables -L

View firewall rules (Windows)

→netsh advfirewall firewall show rule name=all

IDS (Intrusion Detection System)

Types of IDS

NIDS: Network-based IDS

HIDS: Host-based IDS

Detection Methods

Signature-Based Detection

Anomaly-Based Detection

Hybrid Detection

IDS Workflow Diagram:

Example Tool – Snort

Run Snort in packet capture mode

→snort -i eth0 -A console

IPS (Intrusion Prevention System)

Functions

Detect and block malicious traffic.

Automatically update rule sets.

Prevent known attack signatures.

IPS Workflow Diagram:

Example Tool – Suricata

Run Suricata in IPS mode

suricata -c /etc/suricata/suricata.yaml -i eth0



Hands-On Labs

Lab 1 – Configure Linux Firewall (iptables)

Block incoming traffic from an IP

→sudo iptables -A INPUT -s 192.168.1.100 -j DROP

Lab 2 – Detect Suspicious Traffic with Snort

→snort -i eth0 -A console -c /etc/snort/snort.conf

Lab 3 – Prevent Attack with Suricata

→suricata -c /etc/suricata/suricata.yaml -q 0 -i eth0